FileBridge

Full-Stack Architecture & Security Implementation Report

1. System Overview & Security Model

FileBridge is a multi-tenant cloud file management web application engineered with Spring Security 6, stateless JWT bearer tokens, and MongoDB. The system enforces strict user-level ownership isolation across all data operations. Users authenticate through cryptographic credentials, receiving signed tokens validating access to their private file catalog. All attempts to access, download, or delete unauthorized files are intercepted and rejected with uniform 404 responses to eliminate Insecure Direct Object Reference (IDOR) disclosure.

2. Technology Stack

Component	Technology	Version / Specification
Frontend UI & Routing	React 19, React Router 7	Vite 8.3 build engine, React Context API
Design & Typography	Tailwind CSS, Lucide Icons	Tailwind 3.4, Deep Navy & Teal theme
Backend Framework	Spring Boot, Spring Security	Spring Boot 3.2.3, Java 21, BCrypt Password Encoder
Authentication & Tokens	JJWT (io.jsonwebtoken)	JJWT 0.12.5, HMAC-SHA256, 24h configurable expiry
Database & Persistence	MongoDB Community	MongoDB 7.0.15, Spring Data MongoDB indices
Storage Abstraction	FileStorageService Interface	Local filesystem with UUID key mapping (Supabase ready)

3. Authentication & Ownership Architecture

- **User Registration:** Validates name, RFC-5322 email format, and min-8 character passwords. Hashes passwords using BCrypt with salt rounds; enforces safe default ROLE_USER on the server.
- **Stateless JWT Generation:** Issues HMAC-SHA256 tokens containing user ID, name, and email claims signed by a configurable secret (JWT_SECRET).
- **Security Filter Chain:** JwtAuthenticationFilter extracts Bearer headers on every request, decodes claims, verifies signature, and populates SecurityContextHolder with authenticated UserPrincipal.
- **End-to-End Ownership Enforcement:** FileController pulls user identity strictly from the validated UserPrincipal context. Queries use findByOwnerId and findByIdAndOwnerId to guarantee total data isolation.
- **IDOR Defense:** Cross-user queries return 404 Not Found without disclosing metadata existence or filesystem presence.
- **Isolated Quotas:** Storage usage is calculated per-user by summing sizeBytes of files matching ownerId.

4. REST API Endpoint Specifications

Method & Endpoint	Auth	Status	Description & Behavior
`POST /api/v1/auth/register`	Public	201 Created	Registers user, hashes password, returns JWT
`POST /api/v1/auth/login`	Public	200 OK	Validates credentials, returns JWT & user profile
`GET /api/v1/auth/me`	Bearer	200 OK	Returns current authenticated user profile
`GET /api/v1/health`	Public	200 OK	Service liveness health probe
`POST /api/v1/files`	Bearer	201 Created	Uploads file attached to authenticated owner
`GET /api/v1/files`	Bearer	200 OK	Lists all files belonging exclusively to current user
`GET /api/v1/files/{id}`	Bearer	200 / 404	Retrieves metadata only if owned by user
`GET /api/v1/files/{id}/download`	Bearer	200 / 404	Streams bytes with original filename header
`DELETE /api/v1/files/{id}`	Bearer	204 No Content	Deletes file and metadata if owned by user
`GET /api/v1/files/storage-usage`	Bearer	200 OK	Computes storage consumed by current user

5. Frontend User Experience

- **Dedicated Authentication Pages:** Responsive login and registration screens styled with brand colors, field validation, and error alerts.
- **Protected Routing (ProtectedRoute):** Automatically redirects unauthenticated traffic to /login and authenticated users away from auth forms.
- **Persistent Token Management:** Stores bearer token in localStorage for session restoration across browser refreshes.
- **User Sidebar Widget & Logout:** Displays authenticated user's name and email in the sidebar with an instant sign-out action.
- **Authenticated File Streaming:** Custom blob download trigger automatically passes authorization headers when initiating downloads.

6. Automated Verification Matrix (11 of 11 Passed)

Test Case	Verification Scope	Result
Registration & BCrypt	Verify password hashing & default role assignment	PASS
Duplicate Email Rejection	Rejects duplicate registration with 400 Bad Request	PASS
Successful Login	Issues valid signed JWT and safe user object	PASS
Invalid Credentials	Rejects wrong password with 401 Unauthorized	PASS
Protected Endpoints	Unauthenticated calls to /files rejected with 401	PASS
Malformed Token Handling	Forged / expired JWTs rejected with 401	PASS
Upload Ownership	File metadata stored with ownerId matching user ID	PASS
Catalog Isolation	User A cannot view files uploaded by User B	PASS
IDOR Attack Defense	User A cannot download or delete User B's file ID (404)	PASS
User Storage Quotas	Storage usage calculated strictly per owner	PASS
Current Profile (/auth/me)	Returns current authenticated user details	PASS